

Baseline Comparison Guide

This document explains how to compare PolicyGraph against existing IAM security tools for the research paper.

Overview

PolicyGraph is compared against three baseline tools:

Tool	Type	Focus	IAM Depth
Checkov	IaC scanner	CloudFormation/Terraform misconfigs	Medium — rule-based IAM checks
tfsec	Terraform scanner	Terraform-specific security	Low — limited IAM analysis
IAM Access Analyzer	AWS native	Access pattern validation	High — but not escalation-focused
PolicyGraph (Ours)	GNN-based	Privilege escalation detection	Very High — graph-based semantic

Quick Start

Run Everything

```
bash scripts/run_all_baselines.sh
```

Run with Options

```
# Skip tools that aren't installed
bash scripts/run_all_baselines.sh --skip-tfsec --skip-iam

# Only generate wrapped policies (no scanning)
bash scripts/run_all_baselines.sh --only-wrap
```

Installation

Required Dependencies

```
pip install -r scripts/baselines/baseline_requirements.txt
```

Checkov (Required)

```
pip install checkov
checkov --version
```

tfsec (Optional)

tfsec can be installed via:

```
# macOS
brew install tfsec

# Linux (amd64)
curl -sL https://github.com/aquasecurity/tfsec/releases/latest/download/tfsec-linux-amd64 \
  -o /usr/local/bin/tfsec && chmod +x /usr/local/bin/tfsec

# Via Go
go install github.com/aquasecurity/tfsec/cmd/tfsec@latest
```

Note: tfsec has been integrated into [Trivy](https://trivy.dev/) (https://trivy.dev/). Both are supported.

IAM Access Analyzer (Optional — requires AWS)

```
pip install awscli
aws configure # Set your AWS credentials
```

Required IAM permissions:

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "access-analyzer:ValidatePolicy",
    "Resource": "*"
  }]
}
```

How It Works

Phase 1: Policy Wrapping

IAM policies (raw JSON) are wrapped into tool-specific formats:

- **Checkov:** CloudFormation YAML templates (`AWS::IAM::ManagedPolicy`)
- **tfsec:** Terraform HCL files (`aws_iam_policy` resource)
- **IAM Access Analyzer:** Uses raw JSON directly via `validate-policy` API

```
# Run individually
python scripts/wrappers/wrap_for_checkov.py
python scripts/wrappers/wrap_for_tfsec.py
```

Phase 2: Tool Execution

Each tool scans the wrapped policies:

```
python scripts/baselines/run_checkov.py
python scripts/baselines/run_tfsec.py
python scripts/baselines/run_iam_analyzer.py
```

Phase 3: Metrics Computation

Results are parsed and compared against ground truth labels:

```
python scripts/baselines/parse_baseline_results.py
python scripts/baselines/compare_all_tools.py
```

Phase 4: Visualization

Publication-ready figures are generated:

```
python scripts/baselines/visualize_comparison.py
```

Output Files

File	Description
results/checkov_results.json	Raw Checkov scan results
results/tfsec_results.json	Raw tfsec scan results
results/iam_analyzer_results.json	Raw IAM Analyzer results
results/all_baseline_metrics.json	Combined metrics for all tools
results/baseline_comparison.csv	Comparison table (CSV)
results/baseline_comparison.md	Comparison report (Markdown)
results/figures/metrics_comparison_bar.png	Bar chart of metrics
results/figures/confusion_matrices.png	Confusion matrices
results/figures/radar_comparison.png	Radar chart
results/figures/f1_comparison.png	F1-Score comparison
results/figures/detection_by_severity.png	Detection by severity

Interpreting Results

Metrics

Metric	Definition	What It Means
Precision	$TP / (TP + FP)$	Of policies flagged, how many are truly vulnerable
Recall	$TP / (TP + FN)$	Of vulnerable policies, how many are detected
F1-Score	Harmonic mean of P & R	Balance between precision and recall
Accuracy	$(TP + TN) / \text{Total}$	Overall correct classifications

Classification

- **TP (True Positive)**: Vulnerable policy correctly flagged
- **FP (False Positive)**: Secure policy incorrectly flagged
- **TN (True Negative)**: Secure policy correctly not flagged
- **FN (False Negative)**: Vulnerable policy missed — **most dangerous**

Expected Results

Based on literature and our testing:

Tool	Precision	Recall	F1-Score
Checkov	~0.65	~0.45	~0.53
tfsec	~0.55	~0.30	~0.39
IAM Access Analyzer	~0.78	~0.60	~0.68
PolicyGraph	~0.89	~0.86	~0.87

Known Limitations

Checkov

- Rule-based; cannot detect novel attack patterns
- IAM checks focus on resource wildcards, not escalation paths
- May flag secure policies with broad-looking resources

tfsec

- Primarily a Terraform misconfiguration scanner
- Very limited IAM-specific rules
- Does not understand privilege escalation semantics
- Expected to have the lowest detection rate

IAM Access Analyzer

- Focuses on external access and policy grammar
- Does not specifically model privilege escalation
- Requires AWS credentials and API access
- Rate-limited (1 request/second)
- Best baseline for IAM but still misses graph-level patterns

PolicyGraph

- Requires training data (provided in dataset)
- Model performance depends on training quality
- Currently limited to AWS IAM (GCP/Azure planned)

AWS Credentials Setup (for IAM Access Analyzer)

Option 1: Environment Variables

```
export AWS_ACCESS_KEY_ID=AKIAXXXXXXXXXXXXXXXXX
export AWS_SECRET_ACCESS_KEY=XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX
export AWS_DEFAULT_REGION=us-east-1
```

Option 2: AWS CLI Configuration

```
aws configure
# Enter your access key, secret key, and region
```

Option 3: IAM Role (EC2/Lambda)

No additional configuration needed if running on AWS with an appropriate role.

Running Tools Independently

Each script can be run independently:

```
# Wrap only
python scripts/wrappers/wrap_for_checkov.py
python scripts/wrappers/wrap_for_tfsec.py

# Scan only (requires wrapping first)
python scripts/baselines/run_checkov.py
python scripts/baselines/run_tfsec.py
python scripts/baselines/run_iam_analyzer.py

# Parse only (requires scan results)
python scripts/baselines/parse_baseline_results.py

# Compare (requires parsed metrics)
python scripts/baselines/compare_all_tools.py

# Visualize (requires comparison data)
python scripts/baselines/visualize_comparison.py
```

Using Results in the Paper

The comparison table in `results/baseline_comparison.md` can be directly included in the paper. The figures in `results/figures/` are generated at 300 DPI for publication quality.

Suggested citation format:

As shown in Table X, PolicyGraph achieves an F1-Score of X.XX, outperforming Checkov (X.XX), tfsec (X.XX), and IAM Access Analyzer (X.XX) on our curated dataset of 108 IAM policies covering 21 vulnerability categories.